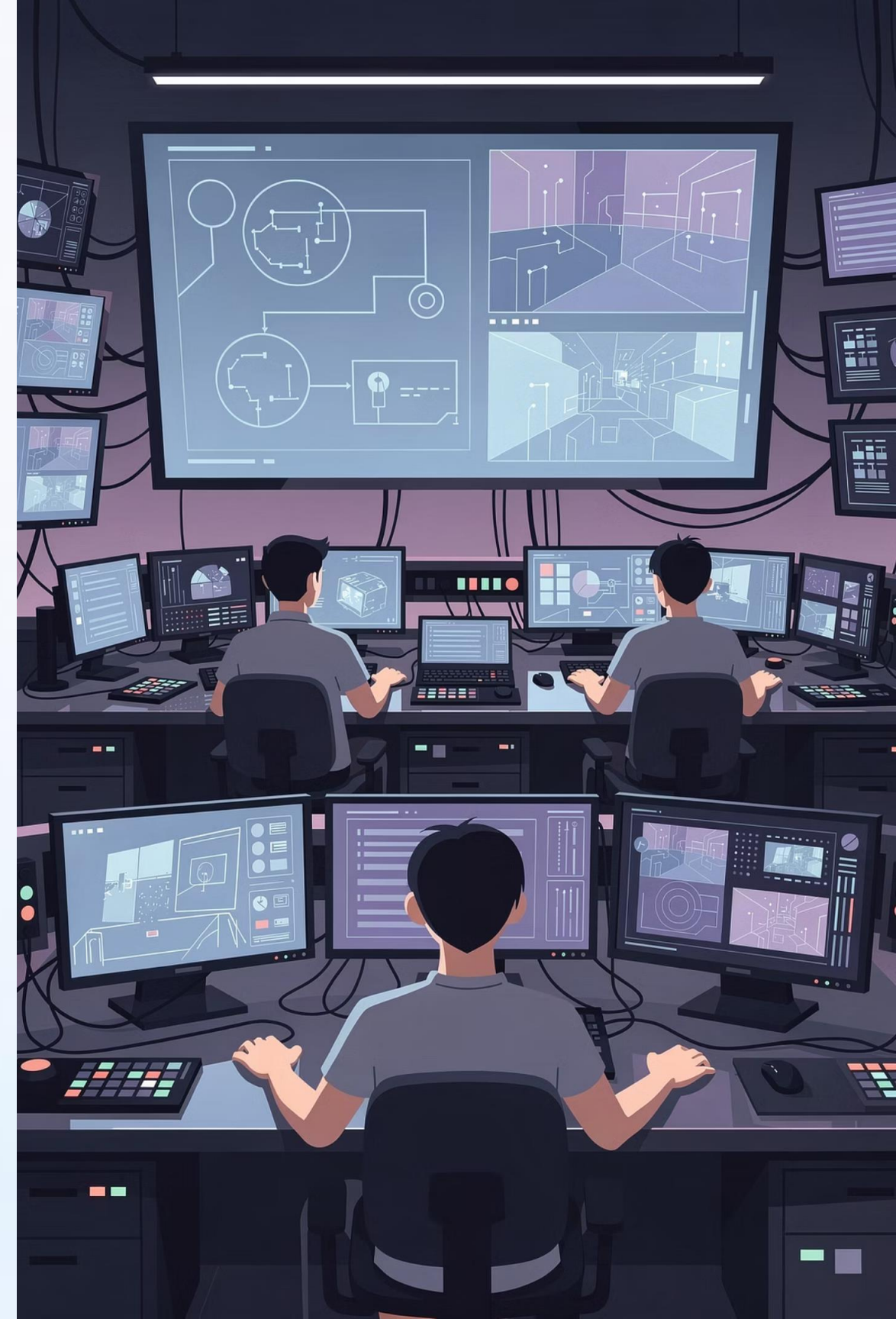


📁 MODULE 02

OT Threat Landscape & Security Standards

Course: Cybersecurity for Embedded & OT Systems

Understanding risks, failures, and defensive security thinking in industrial environments.



Foundations of Embedded & OT Security

Core Concepts

- Embedded systems control **physical devices**
- OT systems manage **industrial processes**
- **Safety and availability** are top OT priorities
- Cyber incidents cause equipment damage, production shutdown, and safety hazards

Architecture & Standards

OT architecture flow:

Sensors → PLCs → HMI / SCADA

OT environments rely on strong safety culture and strict change management.
Standards like **IEC 62443** and **NIST CSF** provide structured thinking.

📌 **Key takeaway:** OT cybersecurity is **safety-first**, not IT-first.

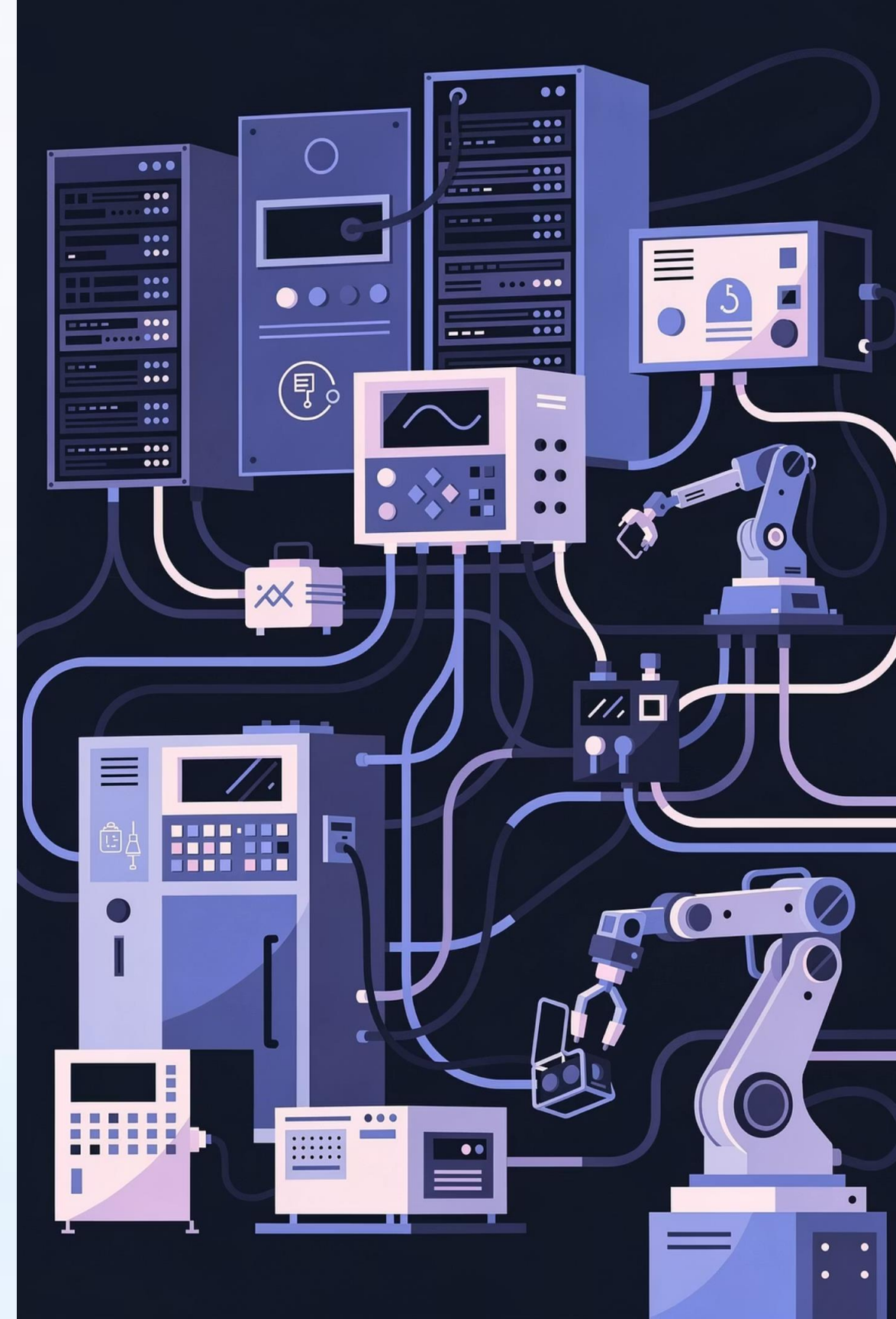
What This Module Is About

Why Study OT Threats?

- OT systems are now connected to IT networks
- Connectivity increases **attack surface**
- OT incidents affect **people, equipment, and operations**
- Many OT failures are **not cyber attacks**

Module Focus

- Understanding real OT threats
- Thinking defensively
- Learning structured security models



What Is a Threat in OT?

A threat in OT is **anything that can disrupt safe operation**. This definition is broader than traditional IT security because it encompasses both malicious and non-malicious events.

Human Errors

Mistakes during operation, maintenance, or configuration changes

Misconfigurations

Incorrect settings that compromise safety or availability

Malware Spillover

Infections spreading from IT to OT networks

Unauthorized Access

Improper or excessive permissions to critical systems

Physical Access Risks

Uncontrolled entry to equipment and facilities

📌 **Important:** Not all threats are intentional or malicious.

Characteristics of OT Threats

Understanding what makes OT threats unique is essential for building effective defenses. The operational context of industrial systems creates a distinct threat profile.

1

Physical and Immediate Impact

Unlike IT systems where threats primarily affect data, OT threats can cause equipment damage, environmental releases, or personnel injuries within seconds.

2

Difficult Detection

Legacy devices often lack logging capabilities, and abnormal behavior may be attributed to mechanical issues rather than cyber incidents.

3

Continuous Operations

Systems run 24/7/365 with limited maintenance windows, making patching and updates extremely challenging to schedule.

4

Safety Verification Required

Recovery isn't complete until systems are verified safe to operate, adding time and complexity to incident response.

5

Long-Lived Legacy Systems

Devices may operate for 20+ years with outdated protocols, unsupported software, and no security features.

Result: Even small mistakes can cause large consequences.

Major OT Threat Categories



Operational Errors

Unintentional mistakes during normal operations or maintenance activities



Configuration Mistakes

Incorrect device settings, network parameters, or control logic



Malware from IT

Infections spreading from enterprise networks to operational technology



Improper Access

Excessive permissions, shared credentials, or unmonitored entry points



Vendor Risks

Third-party maintenance, software supply chain, and contractor access



Physical Access

Unauthorized entry to control rooms, equipment cabinets, or field devices

Key idea: Most OT incidents start from **basic weaknesses** in people, processes, and access controls.

Accidental Failures vs Malicious Activities

Not every OT incident involves an attacker. Understanding the distinction between accidents and attacks is crucial for appropriate response and resource allocation.

Accidental Failures

- No harmful intent
- Caused by human error or process gaps
- Often visible through alarms and monitoring
- Resolved through corrective training and procedures

Malicious Activities

- Intentional misuse or unauthorized access
- Can remain hidden for extended periods
- Require investigation and containment
- May involve legal and regulatory reporting



▮ **Why this matters:** Response actions, investigation depth, reporting requirements, and remediation strategies differ significantly between accidental and malicious incidents.

Insider Errors & Configuration Risks

Insider risk is often **unintentional**. The majority of insider-related incidents in OT stem from process gaps and insufficient controls rather than malicious intent.



Shared Accounts

Multiple users accessing systems with generic credentials removes accountability



Temporary Access

Contractor or vendor permissions not revoked after project completion



Unapproved Changes

Modifications made without proper change control or review process



Poor Documentation

Missing or outdated records of system configurations and settings

High-Risk Configuration Areas

Setpoints

Control thresholds and safety limits

Network Settings

IP addresses, VLANs, firewall rules

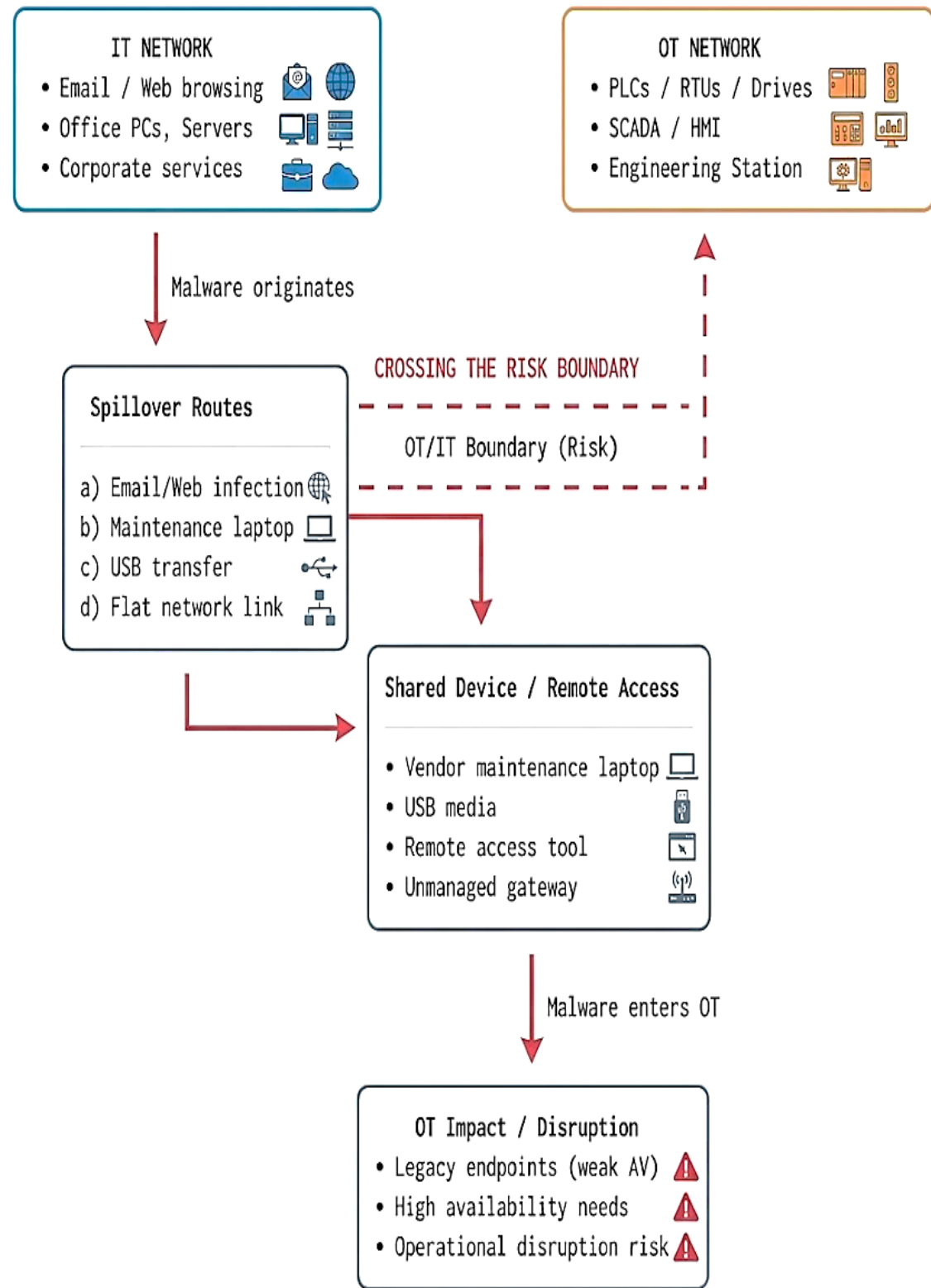
Access Permissions

User roles and authorization levels

Firmware Versions

Device software and patch levels

Lesson: Process discipline reduces risk more effectively than technology alone.



Malware Spillover from IT to OT

One of the **most realistic OT cyber risks** organizations face today. Unlike targeted attacks, spillover happens accidentally and frequently.

1

Infected Laptops

Engineer laptops that connect to both IT and OT networks carry malware across security boundaries

2

USB Devices

Removable media used to transfer files or update firmware become infection vectors

3

Flat Networks

Direct connectivity between IT and OT with inadequate segmentation allows lateral movement

4

Remote Access

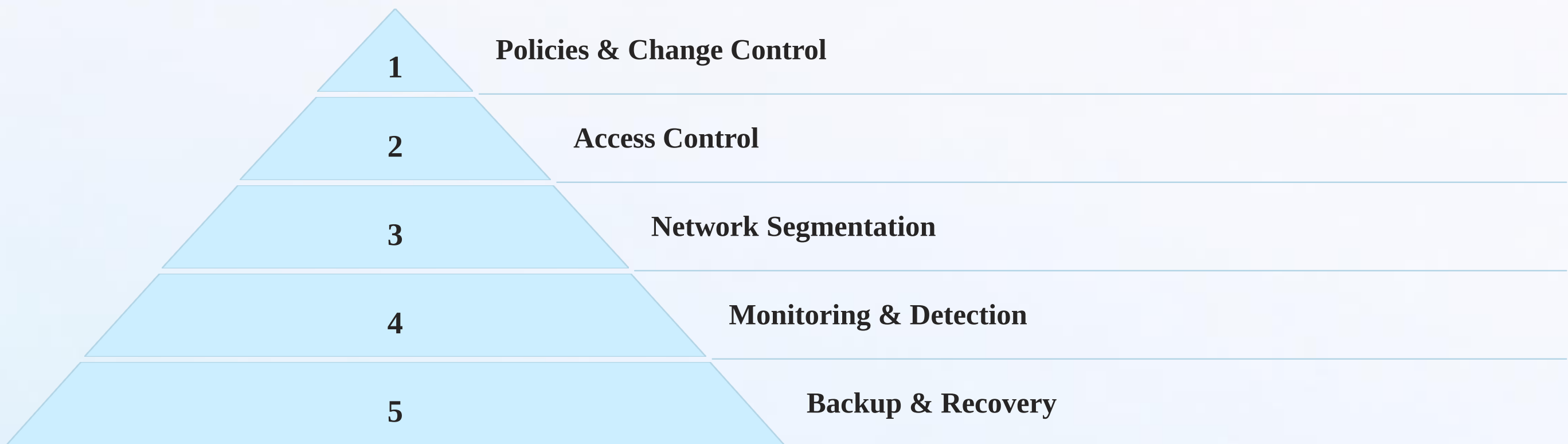
Uncontrolled vendor connections and remote support sessions bypass security controls



Why dangerous? OT devices lack modern endpoint protection capabilities like antivirus or EDR. Even malware not specifically designed for OT can disrupt operations through resource consumption, network traffic, or unexpected system interactions.

Defense-in-Depth Concept

No single control can protect OT systems. **Defense-in-Depth** is a layered security strategy where multiple independent controls work together to reduce risk.



Each layer provides protection, but more importantly, failure of one layer does not compromise the entire system. This redundancy is critical in OT environments where availability and safety cannot be sacrificed.

The concept mirrors physical security practices: fences, guards, badges, cameras, and alarms all work together. If an intruder bypasses one control, others remain active.

Zones & Conduits (IEC 62443)

Organizing systems by **risk and function** is fundamental to OT security architecture. IEC 62443 provides a structured approach using zones and conduits.

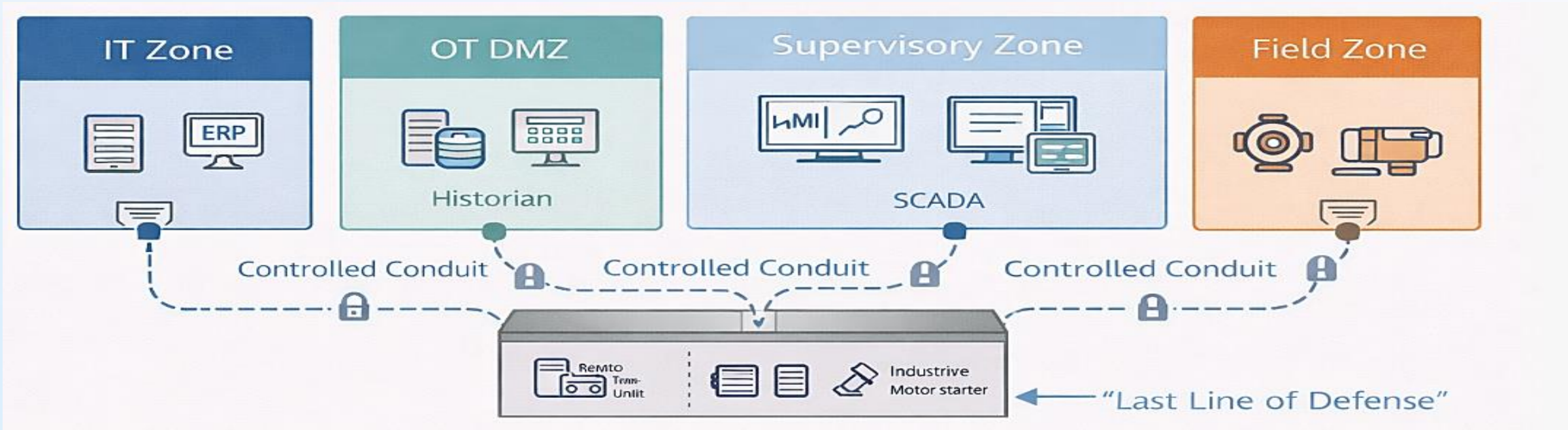
Key Definitions

Zone: A grouping of assets with similar security requirements, risk profiles, and operational characteristics. Assets within a zone share common protection needs.

Conduit: A controlled communication path between zones with defined security requirements. Traffic flowing through conduits can be monitored, filtered, and logged.

01	02	03
Field Devices Zone	Controllers Zone	Supervisory Zone
Sensors, actuators, and instruments at Level 0-1	PLCs, DCS controllers, RTUs at Level 1-2	HMI, SCADA, historians at Level 2-3
04	05	
OT DMZ	Enterprise IT	
Buffer zone for data exchange between OT and IT	Business systems, ERP, email, internet access	

Benefit: Limits the impact and spread of security incidents by containing threats within zones.



NIST Cybersecurity Framework (OT View)

The NIST CSF provides a structured way to manage cybersecurity risk across the organization. When applied to OT, each function requires careful adaptation to operational constraints.

Identify Asset inventory, risk assessment, understanding dependencies	Protect Access controls, training, maintenance, protective technology	Detect Continuous monitoring, anomaly detection, security events
Respond Response planning, communications, analysis, mitigation	Recover Recovery planning, improvements, communications	

OT-Specific Interpretation

Safety Before Speed

Response actions must maintain safe system states. Rapid containment cannot compromise personnel safety or environmental protection.

Controlled Response

Changes during incidents require the same rigor as normal operations. Emergency procedures must be pre-approved and tested.

Verified Recovery

Systems must be proven safe and functional before returning to service. Recovery is not complete until operational acceptance is achieved.

Mapping Threats to Controls

Threats become manageable when systematically mapped to appropriate controls. A comprehensive control framework requires both prevention and detection.

Preventive Controls

Purpose: Reduce the likelihood of incidents occurring

- Access management and authentication
- Network segmentation and firewalls
- Change control procedures
- Security awareness training
- Vendor management processes
- Physical security measures

Detective Controls

Purpose: Improve visibility and enable rapid response

- Network traffic monitoring
- Security information and event management
- Configuration change detection
- Integrity verification
- Access logging and review
- Anomaly detection systems

▬ Both preventive and detective controls are needed to protect OT safely. Preventive controls reduce risk exposure, while detective controls ensure rapid identification and response when prevention fails.

Learning from Industrial Incidents

Public OT incidents reveal repeated patterns and common security gaps. Studying these incidents provides valuable lessons without experiencing the consequences directly.

- 1

Poor IT–OT Segmentation
The most common finding in incident reports. Flat networks or inadequate firewalls allow malware and attackers to move freely between enterprise and operational systems.
- 2

Weak Access Control
Shared credentials, default passwords, excessive permissions, and lack of multi-factor authentication create easy entry points for both insiders and external threats.
- 3

Limited Monitoring
Absence of visibility into OT networks means incidents go undetected for weeks or months. When detection finally occurs, the impact is already severe.
- 4

No Tested Recovery Plan
Organizations discover their backup strategy is inadequate only during an actual incident. Untested plans often fail under real-world conditions.

How to Study Incidents

Focus on **impact** and **root causes** rather than attack steps. Ask: *"What could have prevented this?"* and *"What would have reduced the impact?"*

Incident reports from organizations like ICS-CERT, industrial sector ISACs, and regulatory bodies provide anonymized case studies for learning.

Module 02: What You Should Know Now

After completing this module, you should have a comprehensive understanding of the OT threat landscape and defensive security principles.

OT Threats Are Often Accidental

Most incidents stem from human error, process gaps, or unintentional misconfigurations rather than sophisticated attacks.

Insider Errors Are Common

Shared credentials, poor change control, and inadequate training create frequent operational risks.

Malware Can Spill from IT to OT

Network connectivity and shared devices create pathways for infections to reach operational systems.

Defense-in-Depth Is Essential

Multiple independent layers of security controls work together to protect systems even when individual controls fail.

Zones & Conduits Reduce Exposure

Structured network architecture limits incident scope and provides clear security boundaries.

NIST CSF Structures Security Thinking

A systematic framework for identifying, protecting, detecting, responding, and recovering from incidents.

REFLECTION & CLASS DISCUSSION

•Why OT Threats Are Not Always Cyberattacks

- Difference between accidental failures and malicious activities
- One example of insider-related risk in OT
- How malware can spill over from IT to OT
- Why defense-in-depth is necessary in industrial systems

Homework & Assignments

1. Identify 5 OT threats in a small industrial setup
2. Classify 3 threats as accidental or malicious
3. Map one threat to preventive and detective controls
4. Draw a simple zones and conduits diagram for a pump cell
5. Read short notes on IEC 62443 and NIST CSF (Identify–Recover)

Applied Learning Task (Optional Box)

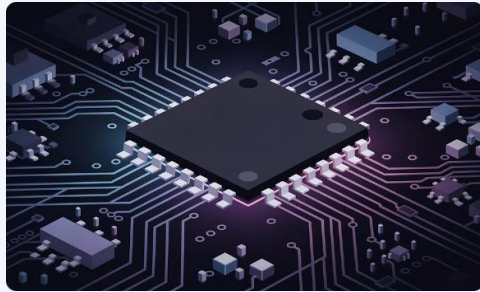
Case Exercise:

Pick one public industrial cyber incident and summarize:

- Impact
- Likely weakness
- One preventive control
- One detective control

Embedded Systems Fundamentals & Secure Boot

In **Module 03**, we move from *understanding OT threats* to *securing the devices themselves*. You'll learn how embedded systems function and how to protect them from the hardware level up.



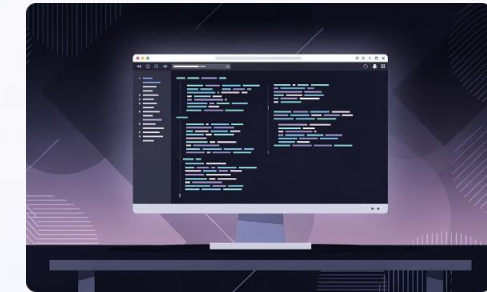
Microcontroller Architecture

CPU, memory, peripherals, and how they're used in industrial systems



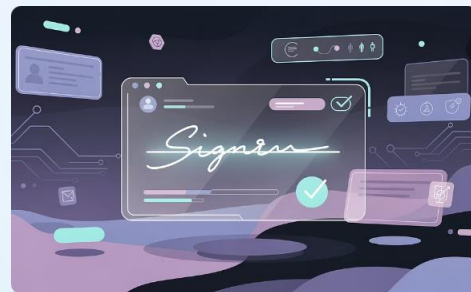
Real-Time Behavior

RTOS concepts, tasks, scheduling, and why timing matters in control systems



Firmware Management

How firmware is created, updated, and secured against unauthorized modification



Secure Boot

Protecting firmware integrity using digital signatures and trusted boot chains



Physical Security

Risks from debug interfaces (UART, JTAG) and safe handling of development boards

Goal of the next module: Understand how embedded devices start, run, and can be protected from unauthorized firmware and physical misuse.

Thank you. Let's continue with **Module 03**.